

FYP-SP-08 • FORMAL PROGRESS REVIEW

Zero Trust Digital Provenance Platform

Concise Project Progress & Deliverables Report

Review focus: What has been delivered, how the implemented system differs from the approved baseline, and what must close before production acceptance.

Project detail	Value
Programme	BS Computer Science — Final Year Project
Institution	FAST NUCES, Karachi Campus
Supervisor	Moheez Ur Raheem
Team	Muhammad Shaheer Zafar; Syed Hasham Uddin; Sohaib Sherwani
Assessment basis	SRS v2.0, SDS v1.0, FYP-I report, repositories and executed checks
Report status	Discussion draft — evidence current to 20 September 2026

01

Executive progress snapshot

The platform is substantially implemented, with a small set of high-impact closure items.

12 complete deliverables	7 partial / superseded	2 not implemented	74% weighted baseline progress
------------------------------------	----------------------------------	-----------------------------	--

Current position

ZTDPP has moved beyond the initial proof of concept into a broad provenance platform. The current system provides secure accounts, API keys, signed and versioned provenance, a hash-chained ledger, perceptual matching, persisted verification reports, administrator tooling, and a separately deployable AI service.

The strongest progress is in provenance lifecycle management, auditability, developer integration, and deployment structure. The remaining work is concentrated in production security closure, AI generalization, formal performance evidence, explainability, and updated SRS/SDS documentation.

Recommended status: Feature-complete for an advanced academic demonstration after targeted blocker closure; not yet approved for unrestricted public production use.

Decisions required now

1. Approve an updated SRS/SDS baseline that reflects the implemented NestJS, MongoDB, Ed25519, Next.js, ledger, and PyTorch architecture.
2. Treat GradCAM and PDF forensic reporting as explicit pending deliverables, or formally remove/replace them in the approved scope.
3. Hold production promotion until the public role route is secured, the known AI regression is resolved, and retained E2E and performance evidence passes.

Scope and architecture evolution

The implementation keeps the project intent while materially changing the technical baseline.

Area	SRS / SDS baseline	Implemented system	Assessment
Core API	FastAPI orchestrator	NestJS API; FastAPI dedicated to AI	Broader separation
Database	SQLite	MongoDB/Mongoose with transactions	Scalable; docs outdated
Signing	ECDSA P-256 embedded in EXIF	Ed25519 signed manifests and ledger receipts	Stronger chain; protocol changed
AI	EfficientNet-B4 via ONNX	ConvNeXt Tiny + residual PyTorch service	Superseded design
Frontend	React/Vite SPA	Next.js 15 App Router	Broader capability
Provenance	Image-embedded manifest	Server-side versioned manifest and lineage	Embedding absent
Verdicts	Verified / Unverified / Blocked	Trusted / Likely authentic / Suspicious / Untrusted	Policy expanded
Explainability	GradCAM heatmap	No heatmap endpoint or UI	Open requirement

Implemented platform shape

- Next.js user and administrator dashboards with 27 page routes.
- NestJS domain API with authentication, roles, provenance, ledger, reports, settings, and API-key modules.
- FastAPI AI service with checkpoint health reporting, image validation, calibrated threshold, and protected prediction endpoint.
- Docker Compose and Caddy deployment topology with health checks, limits, TLS routing, and CI workflows.

Deliverable register — completed foundation

Direct code, runtime, build, or test evidence supports these outcomes.

ID	Deliverable	Status	Evidence summary
T1.1	Dataset acquisition and preprocessing	Complete	Metadata ingestion, hashing, balanced sampling and split validation.
T2.1	UI/UX and JSON schema	Complete	Production Next.js interface and stable API response conventions.
T3.1	Backend architecture and registry	Complete	NestJS modules and MongoDB entities supersede SQLite.
T3.2	Parallel verification orchestrator	Complete / superseded	NestJS runs local evidence and AI request concurrently.
T1.2	CNN architecture and baseline	Complete	ConvNeXt/residual model and training pipeline are present.
T1.3	Full training and fine-tuning	Complete with limitation	Checkpoint metrics are strong; generalization remains unproven.
T3.3	Crypto verifier and registry	Complete / superseded	Hashes, Ed25519 signatures, ledger links and proofs are recomputed.
T2.3	Frontend component development	Complete / superseded	User and administrator workflows span 27 routes.
T3.4	Trust aggregation and verdict	Complete	Configurable metadata/AI weights, hard caps, signals and four verdicts.
T2.6	Developer dashboard	Complete	API-key create, reveal, rotate, revoke, scope, limits and usage.
T3.6	API gateway middleware	Complete	Hashed keys, scopes, rate limits, usage, headers and Swagger.
T3.7	Docker deployment	Complete	Frontend, API, AI, Caddy, health checks and environment templates.

04

Deliverable register — remaining work

Seven deliverables need evidence or scope reconciliation; two are absent.

ID	Deliverable	Status	What remains
T2.2	Signer and tamper tests	Partial / superseded	Formalize replacement design and complete tamper evidence pack.
T2.4	Three-verdict conditional rendering	Partial	Document revised verdict model; original blur/block behavior is absent.
T1.4	ONNX export and inference	Partial / superseded	Formally approve PyTorch runtime or provide ONNX artifact.
T1.5	Empirical S1–S6 evaluation	Partial	Run full standardized adversarial suite and retain results.
T2.5	Frontend integration testing	Partial	Add browser E2E coverage for critical user/admin flows.
T3.5	Load tests, latency and dissertation	Partial	Publish reproducible p50/p95/p99 and throughput evidence.
T1.6	Cross-generator fine-tuning	Partial	Resolve known Gemini false negative and prove held-out recall.
T1.7	GradCAM explainability	Not implemented	Implement for ConvNeXt or formally approve a replacement.
T2.7	PDF forensic report	Not implemented	Generate signed/checksum-bound PDF from saved evidence.

12 / 21 complete	15.5 / 21 weighted points	73.8% weighted completion
----------------------------	-------------------------------------	-------------------------------------

Interpretation: The percentage measures literal delivery against the approved schedule. The implemented platform is broader than the baseline, but changed architecture cannot count as full compliance until the documents are re-baselined.

05

Functional requirement traceability

Eleven SRS use cases mapped to the current workspace.

Use case	Capability	Status	Conclusion
UC-01	Sign image at origin	Partial / superseded	Signed manifests exist; image-embedded signature is absent.
UC-02	Upload for verification	Complete	Validated upload, progress, errors and saved report UI.
UC-03	Parallel verification	Complete / superseded	Hashes/metadata and AI call run concurrently.
UC-04	Cryptographic verification	Complete / superseded	Manifest, signature, ledger and Merkle checks are recomputed.
UC-05	AI anomaly detection	Partial	Service runs; cross-generator false negatives remain.
UC-06	Trust aggregation	Complete	Weighted score, fallback policy, caps, signals and verdicts.
UC-07	Conditional rendering	Partial	Evidence views exist; original blocked-image blur is absent.
UC-08	Manage API keys	Complete	Secure lifecycle, scopes, limits and usage views.
UC-09	External verification API	Complete	Scoped endpoints with rate-limit metadata.
UC-10	History and analytics	Partial	Saved history and JSON export exist; PDF does not.
UC-11	GradCAM heatmap	Not implemented	No computation, response field or visualization.

Traceability result: Core verification and provenance goals are operational. Literal SRS conformance depends on accepting the revised architecture and closing UC-11 or formally replacing it.

How the implemented system works

Operational flow and persistence boundaries.

Provenance registration

- 1. Validate an uploaded image or a privacy-preserving content hash and declared source.
- 2. Compute SHA-256 plus perceptual hashes and normalize available metadata.
- 3. Create a canonical manifest, sign it with Ed25519, and commit the asset and version in MongoDB.
- 4. Append a linked ledger entry; edits point to their parent and revocation adds a new signed event.

Verification and metadata return

- 1. Process uploaded bytes in memory and extract EXIF, XMP, IPTC, PNG text, C2PA-container presence, SHA-256, pHash and dHash.
- 2. Call the AI service while searching exact and indexed near-match provenance claims.
- 3. Recompute signature, manifest, ledger and Merkle evidence instead of trusting stored verdicts.
- 4. Return scores, effective weights, verdict, signals, matched provenance, input metadata and processing time; persist the complete evidence snapshot.

Storage boundaries

Data	Location	Handling
Accounts, sessions, API keys	MongoDB	Passwords/keys hashed; plaintext API key shown once.
Assets, manifests, ledger	MongoDB	Versioned records, signatures, proofs and ownership.
Verification reports	MongoDB	Immutable evidence and policy snapshot.
Uploaded verification bytes	Memory only	Processed then discarded.
AI checkpoint	Read-only model volume	Server-controlled best.pt; excluded from Git.

Quality and production evidence

What has been verified and what still lacks retained proof.

Check	Result	Evidence
Backend automated tests	Passed	52 passed, 10 skipped; 6 suites passed, 1 skipped.
Backend lint and typecheck	Passed	ESLint and TypeScript no-emit checks completed.
Frontend lint and build	Passed	Lint clean; production build generated static and dynamic routes.
AI container and health	Passed	Image built; /health loaded checkpoint and threshold 0.690918.
Formal load/latency suite	Pending	No retained benchmark against all SRS targets.
Automated browser E2E	Pending	No full S1–S7 cross-service acceptance suite.

Security strengths

- HTTP-only cookies, refresh-session rotation, password hashing, OTP expiry and revocation.
- Peppered API-key hashes, scopes, throttling, CORS allowlists, request IDs and redacted logs.
- Upload validation, AI circuit breaker, signing-key history, transactions and hardened containers.

Production blockers

- POST /roles is currently unauthenticated and can affect a privilege boundary.
- Production needs durable signing keys, authenticated TLS MongoDB transactions, backup/recovery and fail-closed readiness checks.
- Horizontal scale needs a single ledger sealer/leader and a shared rate-limit store such as Redis.

AI model status and limitation

Validation metrics are strong; cross-generator reliability is not yet proven.

94.84% validation accuracy	94.79% F1	98.74% ROC-AUC	0.6909 decision threshold
--	---------------------------------	--------------------------------------	---

Evidence	Observed result	Meaning
Checkpoint	forensic-fusion-b4fbb355522c	Versioned production artifact loads correctly.
Edited Gemini image	0.42% AI probability	Severe false negative on generated content.
Three camera photos	0.51%, 0.86%, 1.58%	Low camera scores; lowering threshold is unsafe.
Tiled inference probe	Did not correct miss	Inference reshaping alone is insufficient.

Model risk: A high aggregate validation score does not establish robustness to unseen generators and post-processing. The UI now reports low output as “No AI pixel signal” and flags evidence/model disagreement, but retraining remains necessary.

Promotion gate

1. Build a versioned corpus across Gemini/Imagen, DALL-E, Midjourney, Flux, Firefly, Stable Diffusion, camera images and post-processing variants.
2. Use generator-held-out splits and calibrate only on validation data.
3. Require per-generator recall, camera false-positive, calibration and known-regression gates before promotion.

Priority gap and risk register

Risks ranked by effect on security, acceptance, and trustworthy operation.

ID	Priority	Risk	Required treatment
R1	Critical	Unauthenticated role creation	Remove public route or require JWT plus super-admin; add regression test.
R2	High	AI cross-generator false negatives	Retrain; enforce generator-held-out promotion tests.
R3	High	SRS/SDS architecture drift	Issue approved SRS/SDS revision and change log.
R4	High	GradCAM absent	Implement for ConvNeXt or formally approve replacement.
R5	High	Performance targets unverified	Publish reproducible latency, throughput and resource report.
R6	Medium	PDF report absent	Generate checksum-bound PDF from immutable snapshot.
R7	Medium	External C2PA validation absent	Integrate conforming verifier and trust-store policy.
R8	Medium	Distributed operations unproven	Use leader/single sealer and Redis-backed limiting.
R9	Medium	Full E2E suite absent	Automate S1–S7, auth, revocation, ambiguity and outage cases.

Risk concentration: R1 must close before any public exposure. R2–R5 determine whether the product can claim reliable, explainable, requirements-aligned production performance.

Completion roadmap

Work sequenced by production risk and acceptance value.

Phase A — production blockers

1. Protect/remove public role creation and audit every mutation route.
2. Rotate development credentials; provision durable signing keys and recovery procedures.
3. Deploy authenticated TLS MongoDB replica set and execute readiness/migration checks.
4. Complete S1–S7 plus browser/API E2E automation.
5. Run load and latency benchmarks with p50/p95/p99, throughput, errors, CPU and memory.

Phase B — AI quality and explainability

1. Create the cross-generator, camera and post-processing evaluation corpus.
2. Retrain and calibrate with generator-held-out evaluation and regression gates.
3. Implement GradCAM for ConvNeXt or approve and document a replacement explanation method.

Phase C — deliverables and governance

1. Generate the formal PDF forensic report from the immutable verification snapshot.
2. Publish SRS v3.0 and SDS v2.0 for the actual architecture and security boundaries.
3. Update the dissertation with implementation, model, adversarial and performance evidence.
4. Complete final traceability review and supervisor sign-off.

Suggested review order: Approve the revised baseline first, then use the acceptance gates on the final page as the definition of done.

Acceptance gates and final assessment

A concise definition of done for project completion and production readiness.

Gate	Required evidence	Exit criterion
G1 Functional	Automated S1–S7 plus critical user/admin flows	All critical paths pass
G2 Security	Route audit, secret/dependency/container scans	No unresolved critical/high finding
G3 AI quality	Held-out matrices, per-source recall, camera FPR	Approved metrics; regression passes
G4 Performance	Reproducible p50/p95/p99 and throughput	Targets pass or are formally revised
G5 Reliability	DB/AI/key/restart/ledger recovery tests	Graceful degradation; no corrupt records
G6 Documentation	Approved SRS/SDS, runbook, API guide, model card	Documents match deployment
G7 Deployment	TLS staging, backups, probes, monitoring, rollback	Repeatable deployment and rollback

Final assessment

ZTDPP is no longer an early prototype. It is a coherent, security-aware provenance platform whose implemented capability is broader than the original FYP-I design. Its strongest areas are provenance lifecycle management, ledger evidence, API-key integration, persisted trust reporting, and the user/administrator experience.

The path to completion is clear and finite: close the privilege route, re-baseline the documentation, prove performance and end-to-end behavior, improve AI generalization, and resolve GradCAM and PDF reporting. These items should be treated as acceptance gates.

Discussion conclusion: Proceed with targeted closure work. Do not describe the current build as unrestricted production-ready until G1–G7 are evidenced and approved.

Evidence basis: SRS v2.0; SDS v1.0; FYP-I report; frontend commit 6f3b816; backend commit 927fd63; architecture and production-readiness guides; AI model card; executed build, lint, typecheck, unit-test and container-health checks.